Test Plan — KAN-4

Add Passkey and SSO Login Options to VWO Login Page

Jira: KAN-4 | Type: Story | Priority: Medium (description says High) | Status: To Do | Project: AITraining | Reporter: RM Thomas | Assignee: Unassigned

Document date: 2026-10-31 | Template version 1.0.0 | Prepared by: AI draft (Claude) for QA owner review

> **Status: DRAFT — pending human review.** Not approved until a QA owner signs off. Nothing in this plan is final.

1. Scope & Objectives

Ticket summary (from Jira): As a user, I want to log in using either Passkey or Single Sign-On (SSO), so that I can access my account more securely and conveniently without relying solely on email/password. Two new options, "Sign in using SSO" and "Sign in with Passkey", are added to the login page alongside existing authentication methods.

Acceptance criteria as written in the ticket (labelled for traceability)

Ref	Acceptance criterion
AC-1	**UI visibility:** on the login page, buttons "Sign in using SSO" and "Sign in with Passkey" are visible, displayed below the "Sign in with Google" option.
AC-2	**SSO flow:** clicking "Sign in using SSO" with valid SSO credentials authenticates the user and redirects to the dashboard; appropriate error messages for invalid credentials.
AC-3	**Passkey flow:** clicking "Sign in with Passkey" with a registered, verified passkey logs the user in and redirects to the dashboard; if no passkey is available, a fallback or guidance message is shown.
AC-4	**Error handling:** proper error messages for failed SSO authentication, passkey authentication failure, and unsupported browser/device for passkeys.
AC-5	**Compatibility:** passkey login works on supported browsers/devices only; SSO works across all configured identity providers.
AC-6	**Security:** flows follow secure protocols (OAuth/SAML/WebAuthn); no sensitive data exposed in UI or network logs.

- **In scope:** presence/position of the two new buttons; SSO login (valid and invalid); passkey login (registered, none registered, unsupported browser/device, failure); error messaging; compatibility; security of the new flows; responsiveness and accessibility (listed under the ticket's test scenarios); regression of the existing login methods on the same page.
- **Out of scope (per ticket):** passkey registration flow (separate story); SSO provider configuration.
- **Objective:** "tested" means every AC above has passing, traceable scenarios on an agreed environment and browser matrix, the open questions in Section 2 are answered, and no critical/high defects remain open (ticket's Definition of Done).

2. Gaps & Questions for the author

Checklist result (`requirement-checklist.md`): **present** · **AMBIGUOUS** · **MISSING**.

#	Area	Finding	Question to author
G1	Ticket integrity	**AMBIGUOUS** Jira fields (KAN-4, project AITraining, reporter RM Thomas, priority Medium) differ from the description header (VWO-49, project VWO, reporter Pramod, priority High). The description also contains pasted comments, automated run results (4/4 BLOCKED), and a trailing AI-generated offer to write test cases.	Is KAN-4 the same story as VWO-49? Which priority is correct? Should the pasted comments/run results be treated as part of the requirement or removed?
G2	Environment	**MISSING** No application URL or environment. The earlier automated runs show an empty "App URL" and all 4 cases BLOCKED.	Which URL/environment (staging?) hosts this feature? Is it deployed? Is a feature flag involved?

G3	Compatibility	**AMBIGUOUS** "Supported browsers/devices" for passkeys is undefined.	What is the official browser/OS/device matrix and minimum versions? Platform vs. roaming (security key) authenticators?
G4	SSO	**AMBIGUOUS** "All configured identity providers", "OAuth/SAML", and "valid SSO credentials" are not specific. The steps between clicking the button and the IdP (enter email? org ID? domain discovery?) are not described.	Which IdPs and protocols are configured for testing? What does the user enter after clicking SSO? How is an SSO user matched to an account?
G5	Error messages	**AMBIGUOUS** "Appropriate" / "proper" error messages and the passkey "fallback or guidance message" have no wording. (An earlier automated check assumed "Invalid credentials", which is not in the AC.)	What exact text/behaviour is expected for: failed SSO, failed passkey, no passkey, unsupported browser? Fall back to what?
G6	Unsupported browser	**MISSING** Not stated whether the Passkey button is hidden, disabled, or shown with an error on unsupported browsers.	Which behaviour is intended?
G7	Layout	**AMBIGUOUS** Only "below Sign in with Google" is specified. Order of the two new buttons, spacing, and mobile layout are unspecified. No mockups linked.	Provide design/mockups. Which button comes first?
G8	Account edge cases	**MISSING** Not covered: SSO or passkey for unregistered, deactivated or locked accounts; same email used with password, Google and SSO; users with multiple passkeys; roles/permissions and the redirect target per role.	What should happen in each case? Are there role-specific landing pages?
G9	Interruptions	**MISSING** User cancels the passkey prompt or abandons the IdP page; timeouts; IdP unavailable; browser back button; session expiry.	Expected behaviour and messages?
G10	Security	**AMBIGUOUS** "Secure protocols" and "no sensitive data exposed" are not testable as written. Missing: rate limiting/lockout, session lifetime, interaction with MFA, CSRF/state/nonce handling, replay of assertions.	What security requirements and standards apply? Is MFA expected with SSO/passkey?
G11	Non-functional	**MISSING** Performance targets, accessibility standard (e.g. WCAG level), i18n/localisation, and audit logging are not specified. "UI responsiveness and accessibility" appears only as a test scenario, not an AC.	Which targets/standards apply? Is the login page localised?
G12	Regression / rollout	**MISSING** Impact on existing email/password, Google login, "remember me" and password reset is not stated. No rollback or feature-flag behaviour.	Which existing flows must be regression-tested? Is there a flag/rollback plan?
G13	Test data	**MISSING** No test SSO IdP/accounts or passkey set-up approach.	Who provides SSO test tenant, accounts, and registered passkeys? (Registration is out of scope, so how do testers create passkeys?)
G14	Planning data	**MISSING** No sprint, fix version, estimate, due date, assignee, linked issues or attachments in Jira. "Documentation updated" in the DoD names no document.	Which sprint/release? Who is assigned? Which documentation?

3. Test Scenarios

Priority by risk: **P0** critical path / security, **P1** important, **P2** lower risk. Scenarios marked with a gap depend on the answer to that question, so their expected results are provisional.

ID	Prio	Type	Scenario	Maps to
TS-1	P0	Positive	Both "Sign in using SSO" and "Sign in with Passkey" buttons are visible on the login page.	AC-1
TS-2	P1	Positive	Both buttons appear below "Sign in with Google"; verify their relative order and that the existing methods are still shown.	AC-1, G7

TS-3	P0	Positive	Valid SSO login authenticates the user and redirects to the dashboard.	AC-2, G4
TS-4	P0	Negative	SSO login with invalid credentials shows an error and does not authenticate.	AC-2, AC-4, G5
TS-5	P1	Negative	SSO for an account that is unregistered, deactivated or not provisioned for SSO.	G8
TS-6	P1	Negative	User abandons or cancels the IdP page, IdP times out or is unavailable.	AC-4, G9
TS-7	P1	Compat.	SSO works with each configured identity provider and protocol (OAuth/SAML).	AC-5, G4
TS-8	P0	Positive	Passkey login with a registered, verified passkey logs the user in and redirects to the dashboard.	AC-3, G13
TS-9	P0	Negative	Passkey login when no passkey is registered/available shows fallback or guidance message.	AC-3, G5
TS-10	P1	Negative	Passkey verification fails (wrong authenticator, failed biometric/PIN) and shows an error.	AC-4, G5
TS-11	P1	Negative	User cancels the browser's passkey prompt; the page recovers and stays usable.	G9
TS-12	P0	Negative	Passkey option on an unsupported browser/device shows the intended behaviour and message.	AC-4, AC-5, G3, G6
TS-13	P1	Compat.	Passkey login across the supported browser/OS matrix (platform and roaming authenticators).	AC-5, G3
TS-14	P1	Boundary	User with multiple registered passkeys, and user who has a passkey on a different device.	G8
TS-15	P1	Permissions	SSO and passkey login for users of different roles land on the correct page.	AC-2, AC-3, G8
TS-16	P0	Security	Network/console/UI inspection shows no tokens, assertions, secrets or personal data exposed in the UI or logs.	AC-6
TS-17	P0	Security	Protocol checks: SAML/OAuth `state`/nonce validation, WebAuthn challenge uniqueness and origin binding; replayed or tampered responses are rejected.	AC-6, G10
TS-18	P1	Security	Repeated failed attempts: rate limiting/lockout and session handling after login.	G10
TS-19	P0	Regression	Existing email/password and “Sign in with Google” login still work unchanged; password reset unaffected.	G12
TS-20	P2	Usability	Responsive layout of the new buttons on mobile, tablet and desktop widths.	Ticket scenario, G7, G11
TS-21	P2	Accessibility	Keyboard navigation, focus order, labels and screen-reader names for both buttons and their error messages.	Ticket scenario, G11
TS-22	P2	Data	Same email used across password, Google, SSO and passkey: account linking and no duplicate accounts.	G8
TS-23	P2	Rollout	Behaviour with the feature flag off/on and after rollback (if a flag exists).	G12

4. Test Data & Environment

- **Data:** TBD (G13) — SSO test tenant/IdP(s) with valid and invalid users; deactivated and unprovisioned users; users with 0, 1 and many registered passkeys; role-specific accounts; an account sharing one email across methods.
- **Environment / flags:** TBD (G2) — URL, build and any feature flag not provided. Passkeys may be tested with virtual authenticators in browser dev tools plus at least one real device.
- **Roles / permissions:** TBD (G8) — roles not listed in the ticket.
- **Browser/device matrix:** TBD (G3).

5. Risks & Assumptions

- **Assumptions made:**
  - The acceptance criteria in the ticket description are the intended requirements for KAN-4, even though they carry another key (VWO-49).
  - The pasted comments and automated run results in the description are context only, not requirements.
  - “The dashboard” means the post-login VWO dashboard.
- **Risks:**
  - High: unclear environment and test data have already left all 4 earlier automated cases BLOCKED.
  - High: authentication is security-sensitive; undefined protocol and error behaviour can hide account-takeover or data-exposure defects.
  - Medium: passkey behaviour varies by browser, OS and authenticator, so coverage is hard to bound until the matrix is defined.
  - Medium: changes to the shared login page may regress existing login methods.
  - Low: unstated NFRs (performance, accessibility, i18n) may be discovered late.

6. Entry / Exit criteria

- **Entry:** feature deployed to the agreed test environment; URL and access shared; SSO test IdP and passkey-capable test setup available; open questions G1–G6 answered; plan approved by QA owner.
- **Exit:** all P0 and P1 scenarios executed; all acceptance criteria met (ticket DoD); no critical or high defects open; regression scenario TS-19 passed; QA sign-off completed; documentation updated (document to be named, G14).

7. Resource Allocation

`TBD` — the ticket is unassigned and the company details file (`misc/mycompanydetails.md`) was empty, so no team, roles or tools could be taken from it. Please provide the QA owner, testers, and tooling.

8. Timelines, Sprint Details

`TBD (G14)` — Jira shows no sprint, fix version, estimate or due date. Ticket created 2026-10-31. Status: To Do.

Human Review Gate

> - **I assumed:** KAN-4's description is its real requirement text; the embedded VWO-49 header, comments and run results are context only; “dashboard” is the post-login VWO dashboard.
> - **I could not confirm:** the application URL and environment; supported browsers/devices; IdPs and protocols; exact error and fallback wording; unsupported-browser behaviour; test data; roles; sprint, resources and timelines. Company details were unavailable (empty file).
> - **Open questions blocking sign-off:** G1 (ticket identity), G2 (environment), G3 (browser matrix), G4 (SSO details), G5 (error wording), G6 (unsupported-browser behaviour), G13 (test data). G7–G12 and G14 should be answered before execution.
> - **Approve, or edit, before I write test cases / automation.** No test cases or automation will be written until a human approves this plan.